Securing PSU-ClinicLab

CYS402 Final Project — Team name / member names

Replace this text. Aim for 10–12 minutes.

The application

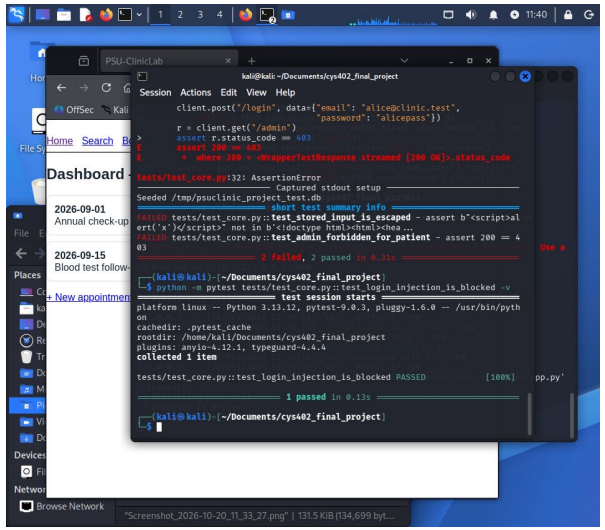
What PSU-ClinicLab does and what is at risk

- One line: what the app does and who uses it
- The data worth protecting (records, logins, admin)
- Your one sentence on why security matters here

Flaw 1 — SQL injection (login bypass)

Attack, cause, fix

- ATTACK
- • Original app let a crafted email value bypass login.
- CAUSE
- • User input was inserted directly into SQL.
- FIX
- • Parameterized queries for login, dashboard, and appointment search.
- PROOF
- • Same payload rejected after the fix.
- • test_login_injection_is_blocked: PASSED (1 passed



Flaw 2 — Stored cross-site scripting

Attack, cause, fix

- Attack: the script you stored and where it ran (screenshot)
- Cause: stored text was rendered as HTML
- Fix: escape output (remove the unsafe rendering)
- Proof: the escaping test now passes

Flaw 3 — Broken access control

Attack, cause, fix

- Attack: a patient opening the admin page (screenshot)
- Cause: the page checked login but not role
- Fix: enforce the admin role
- Proof: patient now gets 403, admin still gets in

Testing evidence

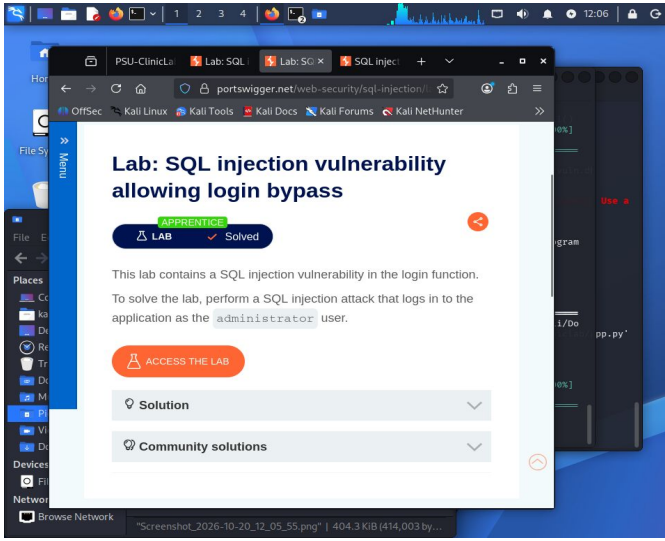
How you proved the fixes

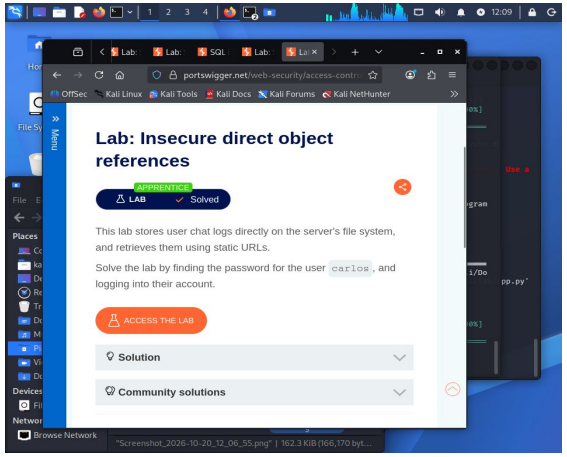
- Show the passing pytest output for the core tests
- Show your own added test and what it checks
- Optional: mention any bonus tests you passed

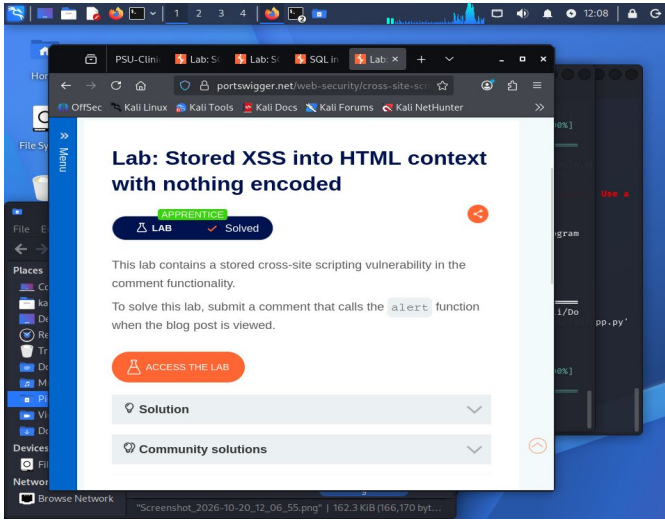
PortSwigger labs

One lab per topic, solved

- Lab 1: SQL injection allowing login bypass — solved
- Lab 2: Insecure direct object references — solved
- Lab 3: one more from your chapter list — solved
- Paste the 'solved' banners







What we would improve

Honest residual risk

- What is still not covered (e.g., MFA, rate limiting, logging)
- One thing you would do next with more time
- Short, honest, specific

Questions

Thank you.